Risk Management Fundamentals

NIST RMF Framework · Governance Structure · HIPAA Compliance Matrix · Framework Mapping

Built on the live HVMC Azure tenant (Entra ID users and groups, HVMC-Prod-VNet, NSGs, EHR storage)

Project Name	Healthcare IAM Operations Simulation
Organization	Horizon Valley Medical Center (HVMC)
Rubric	Risk Management Fundamentals (Semester 4, Week 9)
Evidence Source	Azure subscription "Azure subscription 1", tenant "Default Directory", resource group HVMC-CloudSecurity-RG; collected with Azure CLI on October 13, 2026
Document Version	1.0 (draft)
Prepared By	Sabitha S Karanavar
Report Date	October 13, 2026

Rubric Cross-Reference

Rubric Requirement	Section	Evidence
Risk management framework document (NIST RMF / ISO 31000)	Part 1	NIST RMF 7 steps applied to HVMC, ISO 31000 principles, FIPS 199 categorization of 10 systems, risk scoring scale and risk appetite
Governance structure (roles and escalation)	Part 2	Three Lines governance chart using real tenant users, role table, RACI, escalation matrix with timeframes
HIPAA compliance matrix	Part 3	30 Security Rule standards mapped to HVMC controls and Azure evidence, with Met / Partial / Gap status and remediation plan
Framework mapping diagram	Part 4	Diagram linking NIST RMF steps, NIST CSF 2.0 functions, HIPAA safeguards and HVMC controls, plus a supporting crosswalk table

HVMC environment in scope

Component	Live configuration (Azure, October 13, 2026)
Identity (Entra ID)	32 user accounts: 30 workforce, 1 test account (Test Nurse - EHR), 1 administrator (Sabitha S Karanavar, Global Administrator). 10 role-based security groups. Security defaults enabled (MFA enforced; legacy and device-code sign-in blocked).
Network	HVMC-Prod-VNet 10.0.0.0/16: Web 10.0.1.0/24, App 10.0.2.0/24, Data 10.0.3.0/24, AzureBastionSubnet 10.0.4.0/26. Public load balancer (HVMC-Web-LB), NAT gateway (HVMC-Prod-NatGW), Azure Bastion (HVMC-Bastion).
Network security groups	HVMC-Web-NSG: allow TCP 443 from any. HVMC-App-NSG: allow TCP 8080 from 10.0.1.0/24. HVMC-Data-NSG: allow TCP 1433 from 10.0.2.0/24.

Component	Live configuration (Azure, October 13, 2026)
ePHI storage	hvmcehrstorage: HTTPS-only, minimum TLS 1.2, blob public access disabled, encryption at rest (Microsoft-managed keys), blob soft delete 7 days. Public network access enabled with default action Allow. Custom role HVMC-Nurse-EHR-ReadOnly assigned to the test account.

Part 1 — Risk Management Framework (NIST RMF with ISO 31000 Principles)

1.1 Framework selection

HVMC adopts the **NIST Risk Management Framework (SP 800-37 Rev. 2)** as its primary risk framework, guided by the principles of **ISO 31000:2018**. NIST RMF was selected for three reasons:

- **HIPAA alignment.** HHS points covered entities to NIST guidance (SP 800-66 Rev. 2 maps the HIPAA Security Rule to NIST controls), so RMF evidence can be reused directly for HIPAA risk analysis.
- **System-level structure.** RMF works system by system (EHR, LIS, Pharmacy and so on), which matches how HVMC grants access: one Entra ID security group per application.
- **Continuity with earlier work.** HVMC's cloud risk assessment and compliance reports already use NIST SP 800-53 and NIST CSF controls.

Aspect	NIST RMF (SP 800-37)	ISO 31000:2018	How HVMC uses it
Nature	Prescriptive 7-step process tied to SP 800-53 controls	Principles-based guidelines for any type of risk	RMF is the process; ISO 31000 sets the culture and principles
Scope	Information systems and security/privacy risk	Enterprise-wide (clinical, financial, operational)	Cyber risk feeds the enterprise risk register
Output	Authorization to Operate (ATO) per system	Risk treatment decisions and integrated risk process	Each HVMC system gets an authorization decision
Certification	Not certifiable (federal mandate)	Not certifiable (guidance)	Used as internal standards

ISO 31000 principles adopted by HVMC: risk management is *integrated* into clinical and IT operations; *structured and comprehensive* (one register, one scale); *customized* to healthcare and patient safety; *inclusive* (department managers own their system risks); *dynamic* (monthly review); based on the *best available information* (live Azure configuration and scan data); considers *human and cultural factors* (workforce training); and is *continually improved*.

1.2 System inventory and FIPS 199 security categorization (RMF Step 2 — Categorize)

Each HVMC system is rated Low / Moderate / High for confidentiality (C), integrity (I) and availability (A), following FIPS 199. The overall category is the highest of the three ratings (the "high-water mark").

System	Access group (members)	Data	C	I	A	Overall
Electronic Health Record (EHR)	SG-Doctors-EHR-RW (5), SG-Nursing-EHR-RW (7)	ePHI: diagnoses, orders, notes	High	High	High	**High**
EHR storage (hvmcehrstorage)	Custom role HVMC-Nurse-EHR-ReadOnly	ePHI records and documents	High	High	Mod	**High**
Laboratory Information System	SG-Lab-LIS-RW (3)	ePHI: lab results	Mod	High	Mod	**High**
Pharmacy Management System	SG-Pharmacy-PharmacySystem-RW (3)	ePHI: prescriptions, dosing	Mod	High	High	**High**
IT Administration Console	SG-IT-ITAdmin-Admin (3)	Privileged configuration	High	High	Mod	**High**
Security Monitoring Portal	SG-Security-SecurityPortal-Admin (2)	Logs, alerts, incidents	Mod	High	Mod	**High**

System	Access group (members)	Data	C	I	A	Overall
Appointment Scheduling	SG-Reception-Scheduling-RW (2)	Limited PHI: names, visit times	Mod	Mod	Mod	**Moderate**
HR Portal	SG-HR-HRPortal-RW (2)	Employee PII	Mod	Mod	Low	**Moderate**
Payroll	SG-Finance-Payroll-RW (2)	Salary, bank details	Mod	Mod	Low	**Moderate**
VPN Portal	SG-Contractors-VPN-Read (1)	Remote access gateway	Mod	Mod	Mod	**Moderate**

Integrity is High for LIS and Pharmacy because a changed lab value or dose could directly harm a patient. Availability is High for EHR and Pharmacy because clinicians cannot safely treat patients without them.

1.3 The seven RMF steps applied to HVMC

RMF step	Purpose	HVMC activities and evidence	Status
1. Prepare	Set up risk roles, strategy, risk appetite and organization-wide controls	Governance roles and escalation defined (Part 2). Risk appetite and scoring scale set (1.4). Tenant-wide controls: Entra ID security defaults (MFA), role-based groups.	**Done**
2. Categorize	Describe each system and rate its impact (FIPS 199)	10 systems categorized (1.2): 6 High, 4 Moderate.	**Done**
3. Select	Choose a SP 800-53 control baseline and tailor it	High baseline for EHR, LIS, Pharmacy, IT Admin, Security Portal and EHR storage; Moderate for the rest. Key controls: AC-2 account management, AC-6 least privilege, IA-2 MFA, SC-7 boundary protection, SC-8/SC-28 encryption, AU-2/AU-6 audit logging, CP-9 backup, IR-4 incident handling.	**Done**
4. Implement	Deploy controls and document them	Implemented: 10 RBAC groups (AC-6), security defaults MFA (IA-2), three-tier NSGs (SC-7), Azure Bastion for admin access, HTTPS-only/TLS 1.2 storage (SC-8), encryption at rest (SC-28), soft delete (CP-9). Not yet implemented: activity-log export (AU-6), Data-tier deny rule, storage network restriction.	**Partial**
5. Assess	Test whether controls work as intended	Azure configuration review (Part 3 matrix, October 13, 2026). Vulnerability scan and risk report (September 8, 2026): 2 critical CVEs (CVSS 9.8). Seven control gaps identified (Part 3.5).	**Done**
6. Authorize	Senior official accepts the remaining risk, or not	Proposed: EHR and EHR storage receive a **conditional authorization**, valid for 90 days, provided the High-rated gaps G1–G3 are closed by their target dates. Moderate systems: full authorization, reviewed annually.	**Pending sign-off**
7. Monitor	Track controls and risk continuously	Monthly vulnerability scans; risk register reviewed monthly by the Security & Risk Lead; quarterly access reviews per group; escalation thresholds (Part 2.4). Planned: send Azure activity and sign-in logs to Log Analytics with alert rules.	**Partial**

1.4 Risk scoring scale and risk appetite

Risk score = Likelihood (1–5) × Impact (1–5). Impact is judged on patient safety, ePHI exposure, regulatory penalty and downtime. If a risk could directly harm a patient, its impact is automatically set to 5.

Score	Rating	Risk appetite (what HVMC accepts)	Required action
20–25	**Critical**	Never accepted	Treat immediately; escalate within 24 hours (Part 2.4)
12–19	**High**	Accepted only by the Executive Risk Committee, for at most 90 days	Treatment plan within 7 days
6–11	**Medium**	May be accepted by the system owner, with Security & Risk Lead agreement	Treat within 90 days or accept formally
1–5	**Low**	Accepted	Monitor; review annually

> **HVMC risk appetite statement:** HVMC has a **low appetite** for risks to patient safety and the confidentiality of ePHI, and will not knowingly accept any Critical risk to these areas. HVMC has a **moderate appetite** for operational and financial risk where accepting it enables better patient care.

Part 2 — Governance Structure (Roles and Escalation)

HVMC uses the **Three Lines Model** (IIA, 2020). The first line owns and manages risk day to day, the second line oversees it and sets standards, and the third line provides independent assurance. Names below are the real accounts in the HVMC Entra ID tenant, matched to their job titles.

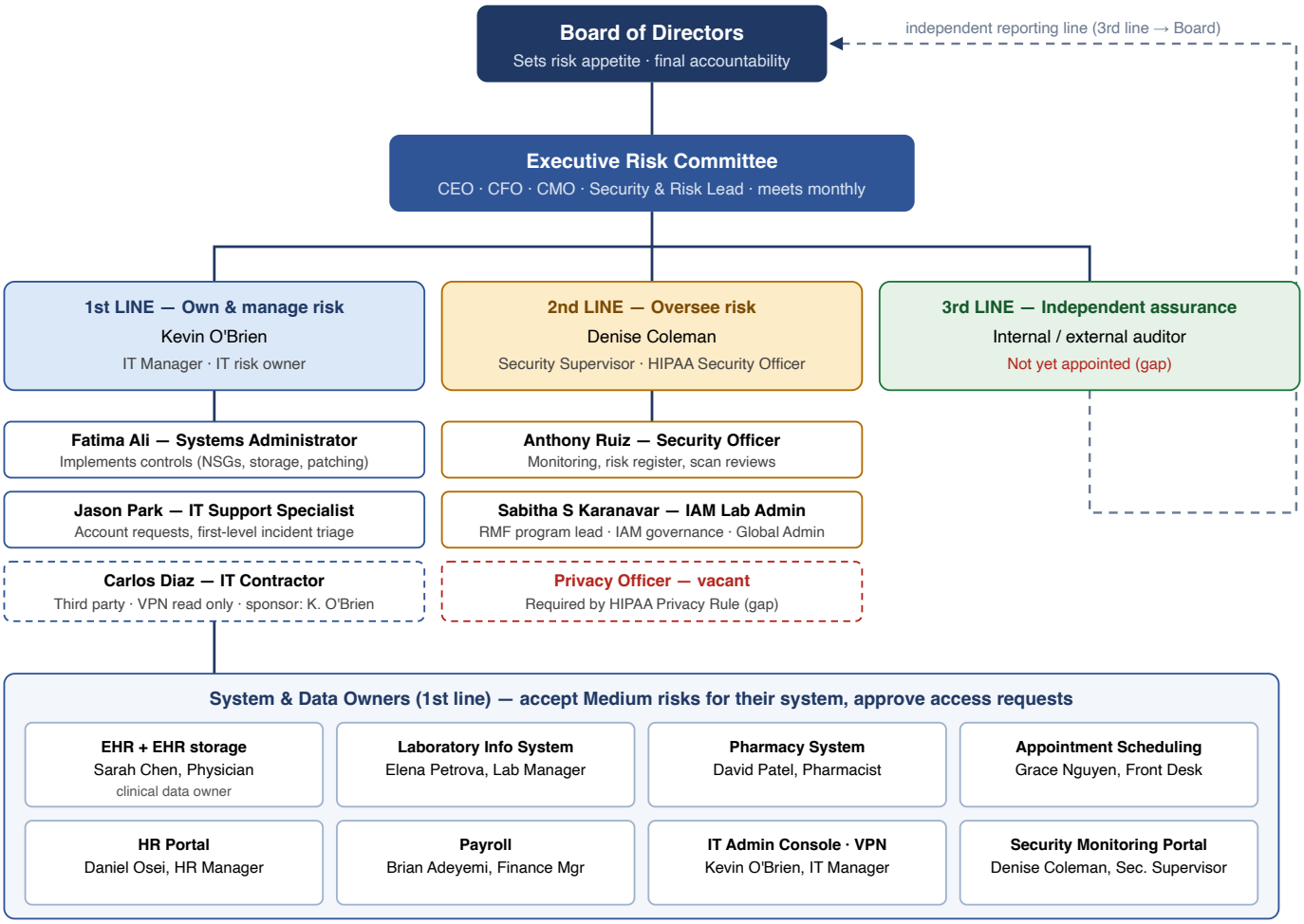


Figure 1 — HVMC risk governance chart (Three Lines Model). Dashed boxes are third-party or vacant roles.

2.1 Roles and responsibilities

Role	Assigned to (Entra ID)	Responsibilities
Board of Directors	Not modeled in tenant	Approves risk appetite; receives the quarterly risk report; accountable for HIPAA compliance.
Executive Risk Committee	CEO, CFO, CMO (not modeled) + Denise Coleman	Approves treatment of High risks and risk acceptances up to 90 days; signs system authorizations (RMF Step 6).
Security & Risk Lead / HIPAA Security Officer	Denise Coleman (Security Supervisor)	Owns the risk register and this framework; the HIPAA "assigned security responsibility" (§164.308(a)(2)); first escalation point for Critical risks.
Security Officer / Risk Analyst	Anthony Ruiz	Runs monthly scans; triages alerts in the Security Monitoring Portal; updates the risk register; prepares monthly metrics.

Role	Assigned to (Entra ID)	Responsibilities
RMF Program Lead / IAM Governance	Sabitha S Karanavar (IAM Lab Administrator)	Runs the RMF process; owns group design and access reviews; the only Global Administrator (see SoD note below).
IT Risk Owner	Kevin O'Brien (IT Manager)	Owns infrastructure risk; approves changes; sponsors contractor access (Carlos Diaz).
Control Implementer	Fatima Ali (Systems Administrator)	Applies technical fixes (NSG rules, storage settings, patches); documents changes.
Service Desk	Jason Park (IT Support Specialist)	Logs access requests and suspected incidents; first-level triage.
System & Data Owners	Sarah Chen, Elena Petrova, David Patel, Grace Nguyen, Daniel Osei, Brian Adeyemi	Approve access to their system; accept Medium risks; certify group membership in quarterly reviews.
Privacy Officer	**Vacant**	Required by HIPAA Privacy Rule (§164.530(a)). Would own breach-notification decisions. Recommended hire or designation.
Workforce users	All 30 workforce accounts	Follow policy; complete annual HIPAA training; report suspected incidents to the Service Desk.

> **Separation of duties finding:** Sabitha S Karanavar is the **only** Global Administrator and the only subscription Owner. That makes one person both the RMF program lead and the only administrator, and a lost account would lock everyone out. Recommendation: create one break-glass emergency account excluded from MFA lockout (stored offline), give Kevin O'Brien a time-limited admin role through Privileged Identity Management, and limit daily work to least-privilege roles. This is tracked as gap G4 in Part 3.

2.2 RACI for key risk activities

R = Responsible, A = Accountable, C = Consulted, I = Informed.

Activity	Board	Exec Risk Cttee	D. Coleman	A. Ruiz	S. Karanavar	K. O'Brien	F. Ali	System owners
Set risk appetite	A	R	C	I	I	I	–	I
Maintain risk register	–	I	A	R	C	C	–	C
Categorize systems (FIPS 199)	–	I	A	C	R	C	–	C
Approve access to a system	–	–	I	–	R	C	–	A
Quarterly access review	–	I	A	C	R	I	–	R
Implement technical controls	–	–	C	I	C	A	R	I
Monthly vulnerability scan	–	–	A	R	I	C	C	I
Accept a High risk	I	A	R	C	C	C	–	C
Authorize a system (RMF Step 6)	I	A	R	C	R	C	–	C
Respond to a security incident	I	I	A	R	C	R	R	I

2.3 Escalation path

Risks and incidents are raised by anyone to the **Service Desk (Jason Park)**, triaged by the **Security Officer (Anthony Ruiz)**, and escalated according to the rating, using the matrix below. Each step up the chain must be logged in the risk register with a timestamp.

2.4 Escalation matrix

Rating	Example from HVMC	Escalate within	Escalate to	Decision rights
Critical (20–25)	Confirmed ePHI exposure from hvmcehrstorage; CVSS 9.8 RCE on a public server	1 hour (incident) / 24 hours (risk)	Denise Coleman → Executive Risk Committee → Board chair. Privacy Officer (once appointed) for breach assessment.	Executive Risk Committee; cannot be accepted
High (12–19)	Data tier reachable from Web subnet; no audit log export	24 hours / 7 days for plan	Anthony Ruiz → Denise Coleman → Executive Risk Committee (monthly report)	Executive Risk Committee may accept for up to 90 days
Medium (6–11)	Test account in production tenant; contractor account with no end date	7 days	Anthony Ruiz → system owner + Kevin O'Brien	System owner, with Security & Risk Lead agreement
Low (1–5)	Typo in a group description	Next monthly review	Recorded in register by Anthony Ruiz	Security Officer

HIPAA breach clock: if unsecured PHI is breached, affected individuals must be notified without unreasonable delay and no later than 60 days after discovery (§164.404). That is why Critical incidents reach the executive level within 1 hour.

Part 3 — HIPAA Security Rule Compliance Matrix

Each standard of the HIPAA Security Rule (45 CFR Part 164, Subpart C) is mapped to the HVMC control that meets it and the evidence collected from the live Azure tenant. **(R)** = required, **(A)** = addressable. Status: **Met** · **Partial** · **Gap**.

3.1 Administrative safeguards (§164.308)

HIPAA standard	HVMC control	Evidence (Azure / project)	Status
§164.308(a)(1)(ii)(A) Risk analysis (R)	NIST RMF categorize + assess; annual and post-change risk analysis	FIPS 199 inventory (Part 1.2); Sept 8 risk report (2 critical CVEs); this matrix	**Met**
§164.308(a)(1)(ii)(B) Risk management (R)	Risk register, scoring scale, appetite, treatment plans	Parts 1.4 and 3.5; monthly register review	**Met**
§164.308(a)(1)(ii)(C) Sanction policy (R)	Workforce sanctions for policy violations	Not yet written	**Gap**
§164.308(a)(1)(ii)(D) Information system activity review (R)	Regular review of sign-in and activity logs	Security Monitoring Portal assigned to SG-Security; but **0 subscription diagnostic settings**, so Azure activity logs are kept only 90 days and not centrally reviewed	**Partial**
§164.308(a)(2) Assigned security responsibility (R)	Named HIPAA Security Officer	Denise Coleman (Part 2.1)	**Met**
§164.308(a)(3)(ii)(A) Authorization and/or supervision (A)	Access approved by system owner; group per role	10 SG-* groups; owners assigned in Part 2	**Met**
§164.308(a)(3)(ii)(C) Termination procedures (A)	Disable account and remove groups on exit; contractor expiry	Termination process from Semester 3 IAM lab. Carlos Diaz (contractor) has **no account expiration** — Week 9 "Contractor Auto-Expiration" task	**Partial**
§164.308(a)(4)(ii)(B)–(C) Access authorization; establishment and modification (A)	Role-based access through security groups; least privilege	Doctors 5, Nursing 7, Lab 3, Pharmacy 3, Reception 2, HR 2, Finance 2, IT 3, Security 2, Contractors 1 — each user in exactly one role group	**Met**
§164.308(a)(5)(ii)(A) Security reminders (A)	Annual HIPAA training and periodic reminders	Training plan in Compliance Program report; completion not yet tracked	**Partial**
§164.308(a)(5)(ii)(C) Log-in monitoring (A)	Monitor failed and risky sign-ins	Security defaults block risky legacy sign-ins (seen: AADSTS530035 on device-code login); sign-in logs not exported	**Partial**
§164.308(a)(5)(ii)(D) Password management (A)	Entra ID password policy + MFA	Security defaults require MFA registration for all users	**Met**
§164.308(a)(6) Security incident procedures (R)	Incident response playbook and escalation matrix	HVMC_Cloud_SecOps_and_Incident_Response.pdf; Part 2.4	**Met**
§164.308(a)(7)(ii)(A)–(B) Data backup; disaster recovery plan (R)	Backups of ePHI and documented recovery	Blob soft delete 7 days on hvmcehrstorage; **versioning off**; no DR test performed	**Partial**
§164.308(a)(8) Evaluation (R)	Periodic technical and non-technical evaluation	This assessment (October 13, 2026); monthly scans	**Met**

HIPAA standard	HVMC control	Evidence (Azure / project)	Status
§164.308(b)(1) Business associate contracts (R)	BAA with cloud provider and contractors	Microsoft offers a HIPAA BAA through its Product Terms (must be confirmed for this subscription); no BAA on file for contractor	**Partial**

3.2 Physical safeguards (§164.310)

HIPAA standard	HVMC control	Evidence	Status
§164.310(a)(1) Facility access controls	Inherited from Microsoft Azure datacenters (shared responsibility)	Azure SOC 2 Type II / ISO 27001 reports (Service Trust Portal)	**Met (inherited)**
§164.310(b)–(c) Workstation use and security	Admin access only through Azure Bastion, no public RDP/SSH on VMs	HVMC-Bastion in AzureBastionSubnet 10.0.4.0/26; no NSG allows 22/3389 from the internet	**Met**
§164.310(d)(1) Device and media controls	Disposal and reuse of media holding ePHI	Azure media sanitization inherited; endpoint/media policy for HVMC laptops not written	**Partial**

3.3 Technical safeguards (§164.312)

HIPAA standard	HVMC control	Evidence (Azure)	Status
§164.312(a)(2)(i) Unique user identification (R)	One named account per person	30 named workforce accounts. Test Nurse - EHR is a shared test account in the production tenant, holding the HVMC-Nurse-EHR-ReadOnly role on hvmcehrstorage	**Partial**
§164.312(a)(2)(ii) Emergency access procedure (R)	Break-glass account and procedure	Only one Global Administrator; no break-glass account	**Gap**
§164.312(a)(2)(iii) Automatic logoff (A)	Session timeout for clinical apps	Not configured (would need Conditional Access sign-in frequency, which requires Entra ID P1)	**Partial**
§164.312(a)(2)(iv) Encryption and decryption (A)	Encryption at rest for ePHI	hvmcehrstorage: blob encryption enabled (Microsoft-managed keys); infrastructure double encryption off	**Met**
§164.312(a)(1) Access control — network layer	Three-tier segmentation with NSGs	Web→App only on TCP 8080 (from 10.0.1.0/24); App→Data only on TCP 1433 (from 10.0.2.0/24). But HVMC-Data-NSG has **no deny rule**, so the default rule AllowVnetInBound (priority 65000) still lets the Web subnet reach the Data subnet on any port	**Partial**
§164.312(a)(1) Access control — storage	Restrict ePHI storage to the private network	hvmcehrstorage public network access **Enabled**, firewall default action **Allow**; anonymous blob access disabled; shared-key access enabled	**Gap**
§164.312(b) Audit controls (R)	Record and examine activity in systems with ePHI	No diagnostic settings for subscription activity log or storage logs; Microsoft Defender for Cloud has only foundational CSPM enabled (no workload protection plans)	**Gap**
§164.312(c)(1) Integrity (R)	Protect ePHI from improper change or deletion	Role-based write access; soft delete 7 days; blob versioning off	**Partial**
§164.312(d) Person or entity authentication (R)	MFA for all users	Entra ID security defaults enabled — MFA enforced, legacy and device-code sign-in blocked	**Met**

HIPAA standard	HVMC control	Evidence (Azure)	Status
§164.312(e)(1) Transmission security (R)	Encrypt ePHI in transit	HVMC-Web-NSG allows only TCP 443 inbound; storage HTTPS-only, minimum TLS 1.2	**Met**

3.4 Policies, procedures and documentation (§164.316)

HIPAA standard	HVMC control	Evidence	Status
§164.316(a) Policies and procedures (R)	Written security policies	Compliance Program Development policy document; this framework	**Met**
§164.316(b)(2)(i) Retain documentation 6 years (R)	Store policies, assessments and logs for 6 years	Documents kept in GitHub (versioned); Azure logs not retained beyond 90 days	**Partial**

3.5 Compliance summary and remediation plan

Safeguard area	Standards assessed	Met	Partial	Gap
Administrative (§164.308)	15	8	6	1
Physical (§164.310)	3	2	1	0
Technical (§164.312)	10	3	4	3
Documentation (§164.316)	2	1	1	0
Total	**30**	**14 (47%)**	**12 (40%)**	**4 (13%)**

ID	Gap	Risk (L×I)	Remediation (Azure CLI where applicable)	Owner	Target
G1	No audit log export (§164.312(b))	**4×5=20 Critical**	Create a Log Analytics workspace and send subscription activity, Entra sign-in and storage logs to it: `az monitor diagnostic-settings subscription create`; set retention to meet the 6-year rule via archive tier	Fatima Ali	Oct 24
G2	EHR storage open to public networks	**3×5=15 High**	`az storage account update -n hvmcehrstorage --default-action Deny --public-network-access Disabled --allow-shared-key-access false`; add a private endpoint in HVMC-Data-Subnet	Fatima Ali	Oct 24
G3	Data subnet reachable from Web subnet (default AllowVnetInBound)	**3×5=15 High**	`az network nsg rule create -g HVMC-CloudSecurity-RG --nsg-name HVMC-Data-NSG -n Deny-All-VNet-Inbound --priority 4000 --access Deny --direction Inbound --source-address-prefixes VirtualNetwork --destination-port-ranges '*' --protocol '*'`; same pattern for HVMC-App-NSG	Fatima Ali	Oct 17
G4	Single Global Admin, no emergency access	**3×4=12 High**	Create a break-glass cloud-only Global Admin with a long random password stored offline; monitor its sign-ins; add a second admin with time-limited elevation	Sabitha S Karanavar	Oct 17
G5	No sanction policy	**2×4=8 Medium**	Write a workforce sanction policy; HR to approve and include it in annual training	Daniel Osei	Oct 31

ID	Gap	Risk (L×I)	Remediation (Azure CLI where applicable)	Owner	Target
G6	Contractor account never expires; no BAA	**2×4=8 Medium**	Set an end date and access review for Carlos Diaz (Week 9 Contractor Auto-Expiration task); sign a BAA	Kevin O'Brien	Oct 17
G7	Shared test account in production with access to ePHI storage	**2×3=6 Medium**	Move Test Nurse - EHR to a non-production subscription, or remove its role assignment when testing ends	Sabitha S Karanavar	Oct 24
G8	Blob versioning off; DR untested	**2×4=8 Medium**	`az storage account blob-service-properties update -n hvmcehrstorage --enable-versioning true --delete-retention-days 30` ; run a restore test	Fatima Ali	Oct 31

Part 4 — Framework Mapping Diagram

The diagram shows how one HVMC control satisfies several frameworks at once. Each row is a NIST Cybersecurity Framework 2.0 function. Reading left to right: the **NIST RMF step** that produces the work, the **CSF function** it supports, the **HIPAA safeguards** it satisfies, and the **HVMC controls and evidence** that prove it.

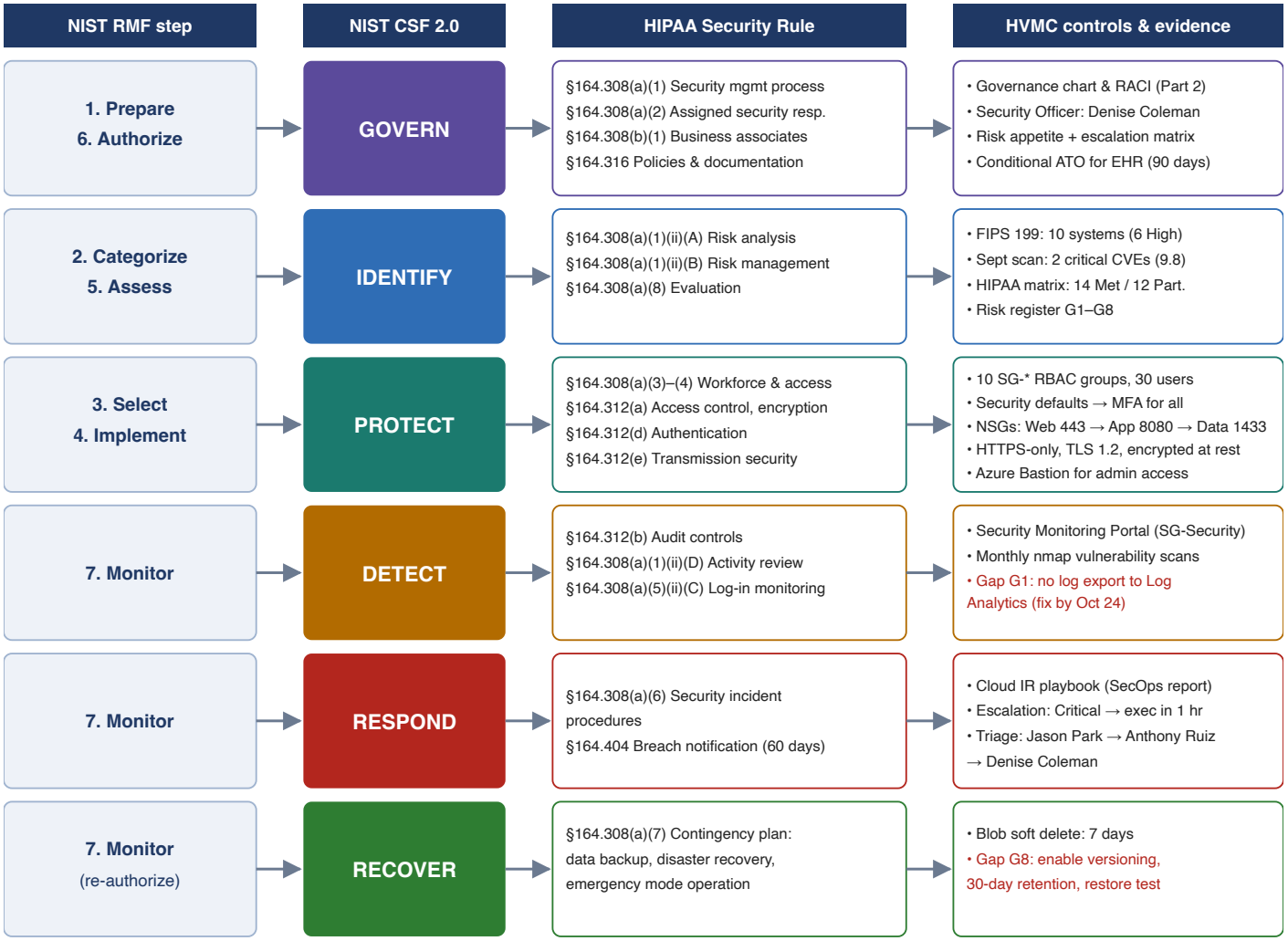


Figure 2 — HVMC framework mapping: NIST RMF → NIST CSF 2.0 → HIPAA Security Rule → HVMC controls. Red text marks open gaps.

4.1 Supporting crosswalk (one control, many frameworks)

HVMC control	NIST SP 800-53	NIST CSF 2.0	HIPAA	ISO 31000 process
Role-based SG-* security groups	AC-2, AC-6	PR.AA-05	§164.308(a)(4), §164.312(a)(1)	Risk treatment
Security defaults (MFA)	IA-2(1), IA-2(2)	PR.AA-03	§164.312(d)	Risk treatment
Three-tier NSGs (Web/App/Data)	SC-7, AC-4	PR.IR-01	§164.312(a)(1), §164.312(e)(1)	Risk treatment
TLS 1.2 / HTTPS-only storage	SC-8	PR.DS-02	§164.312(e)(2)(ii)	Risk treatment

HVMC control	NIST SP 800-53	NIST CSF 2.0	HIPAA	ISO 31000 process
Encryption at rest (hvmcehrstorage)	SC-28	PR.DS-01	§164.312(a)(2)(iv)	Risk treatment
Azure Bastion admin access	AC-17, SC-7	PR.AA-05, PR.IR-01	§164.310(c), §164.312(a)(1)	Risk treatment
FIPS 199 categorization	RA-2	ID.AM-05	§164.308(a)(1)(ii)(A)	Risk identification
Monthly vulnerability scans	RA-5, CA-7	ID.RA-01, DE.CM-08	§164.308(a)(8)	Risk analysis; monitoring & review
Risk register + scoring scale	RA-3, PM-9	GV.RM-01, ID.RA-05	§164.308(a)(1)(ii)(B)	Risk evaluation
Governance chart + escalation matrix	PM-2, PM-9	GV.RR-01, GV.RR-02	§164.308(a)(2)	Leadership & commitment; communication
Quarterly access reviews	AC-2(3), PS-4	PR.AA-05	§164.308(a)(3)(ii)(C)	Monitoring & review
Log Analytics export (planned, G1)	AU-2, AU-6, AU-11	DE.CM-01, DE.AE-03	§164.312(b)	Monitoring & review
IR playbook + escalation	IR-4, IR-6	RS.MA-01, RS.CO-02	§164.308(a)(6)	Communication & consultation
Soft delete / versioning (G8)	CP-9, CP-10	RC.RP-01	§164.308(a)(7)(ii)(A)	Risk treatment

Conclusion

All four parts of the Risk Management Fundamentals rubric are covered. HVMC now has a documented NIST RMF process guided by ISO 31000 principles, with all 10 systems categorized (Part 1). It has a Three Lines governance structure using real tenant users, with a RACI and time-bound escalation (Part 2). A HIPAA Security Rule matrix built on live Azure evidence shows 14 standards met, 12 partially met and 4 gaps (Part 3). A mapping diagram shows how each HVMC control satisfies NIST RMF, NIST CSF and HIPAA together (Part 4). The highest-priority actions are G1 (audit log export), G2 (lock down EHR storage) and G3 (Data-tier deny rule). These are the conditions for authorizing the EHR.

References

- NIST SP 800-37 Rev. 2, *Risk Management Framework for Information Systems and Organizations* (2018).
- NIST SP 800-53 Rev. 5, *Security and Privacy Controls*; FIPS 199, *Standards for Security Categorization*.
- NIST Cybersecurity Framework (CSF) 2.0 (February 2024).
- NIST SP 800-66 Rev. 2, *Implementing the HIPAA Security Rule: A Cybersecurity Resource Guide* (2024).
- ISO 31000:2018, *Risk management — Guidelines*.
- 45 CFR Part 164, Subpart C (HIPAA Security Rule) and §164.404 (Breach Notification).
- IIA, *The IIA's Three Lines Model* (2020).
- HVMC project evidence: Risk_Management_Rubric_Final_Report.pdf (Sept 8, 2026); HVMC_Cloud_SecOps_and_Incident_Response.pdf; HVMC_Cloud_Compliance_and_Governance_Controls.pdf; Azure CLI output, October 13, 2026.